

# Enumeracion de DNS

## Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

## Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

## Fundamentos técnicos

Enumerar DNS es sacarle al servidor de nombres toda la información de dominios y subdominios que gestiona: registros A/AAAA (IPs), MX (correo), TXT (a veces con pistas), y sobre todo intentar una transferencia de zona (AXFR), que si esta mal configurada te da TODOS los registros de golpe, como si te regalaran el mapa completo.

AXFR existe para que servidores DNS secundarios se sincronicen con el primario, pero si el servidor no restringe quien puede pedirla, cualquiera puede solicitarla y recibir el listado completo de subdominios/hosts internos. Es una mala configuración clásica, no una vulnerabilidad del protocolo en si.

## Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final  
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

## Superficie de ataque

Cuando el recon muestra el puerto 53 abierto, o cuando conoces un dominio del objetivo (visto en un certificado TLS, un email, o la propia room) y quieres descubrir subdominios/hosts internos asociados.

## Cómo identificarla

- Puerto 53 (TCP/UDP) abierto en el objetivo.
- Un hostname en un certificado TLS o un email que revela el dominio interno a enumerar.
- dig axfr no devuelve REFUSED sino una lista de registros.

## Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

## Prueba mínima

Intenta una transferencia de zona (AXFR) contra el servidor DNS del dominio conocido.

Evidencia esperada: Si funciona, una lista completa de registros (subdominios, IPs internas, hostnames) en la respuesta. Si falla, el servidor la tiene bien configurada; pasa a fuerza bruta de subdominios.

## Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.

3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

## Capa 1: prueba documentada

```
dig axfr @$IP dominio.local
```

Objetivo y contexto: Intenta la transferencia de zona directamente. Es la prueba mas rentable: si el servidor la permite, obtienes todos los registros sin fuerza bruta.

Resultado esperado: Si funciona, una lista completa de registros A/CNAME/MX con nombres de host internos. 'Transfer failed' o REFUSED significa que esta bien configurado.

## Anatomía de los payloads

La primera prueba es `dig axfr @$IP dominio.local`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

## Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

## Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

## Evidencias de confirmación

Si funciona, una lista completa de registros (subdominios, IPs internas, hostnames) en la respuesta. Si falla, el servidor la tiene bien configurada; pasa a fuerza bruta de subdominios.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

## Escalado de impacto

- Prueba AXFR directamente contra el servidor DNS del dominio conocido; es rapido y, si funciona, te da todo de golpe.
- Si falla, haz fuerza bruta de subdominios con una wordlist y anade los que resuelvan a /etc/hosts.
- Cruza los hostnames encontrados con vhosts web (1fi y el resto de bugs web pueden variar por vhost).
- Si el objetivo es un DC de Active Directory, el DNS suele revelar el nombre del dominio y del propio DC: mira ad-modelo.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

## Errores frecuentes

- El servidor rechaza la transferencia de zona (respuesta 'Transfer failed' o REFUSED) y no conoces mas nombres para probar por fuerza bruta.
- No hay ningun dominio conocido ni servidor DNS accesible para el objetivo.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

## Diagnóstico de payloads fallidos

| Síntoma              | Posible causa                  | Prueba de diagnóstico         | Adaptación                 |
|----------------------|--------------------------------|-------------------------------|----------------------------|
| Rechazo inmediato    | Formato o precondition         | Repetir entrada válida        | Corregir transporte        |
| Sin diferencia       | Entrada ignorada o canal ciego | Marcador y control negativo   | Buscar evidencia adecuada  |
| Error del componente | Contexto o versión             | Reducir a prueba mínima       | Consultar manual detectado |
| Resultado parcial    | Permisos/restricción           | Comprobar identidad y alcance | Reducir primitiva          |

## Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

## Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

## Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

## Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

## Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

## Resumen

El DNS revela subdominios, hostnames internos y a veces todo el mapa de la zona si el servidor permite una transferencia. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

## Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

## Referencias

- [Concepto fuente de THM Fieldbook](#) (dns - enum)
- [Referencia técnica externa](#)

## Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.